Risk Assessment Methodology
Amman National Bank

1. Purpose

The purpose of this Risk Assessment Methodology is to establish a consistent, structured, and repeatable approach for identifying, analyzing, evaluating, and treating information security risks within the approved Information Security Management System (ISMS) scope of Amman National Bank.

This methodology ensures that information security risks are assessed using a common process to support risk-based decision-making, regulatory compliance, and continual improvement of the ISMS.

2. Scope

This methodology applies to all information assets, business processes, supporting technologies, personnel, and services included within the approved ISMS scope of Amman National Bank.

The methodology applies to the following areas:

- Core Banking
- Digital Banking
- Payments
- ATM Services
- Identity and Access Management (IAM)
- Security Monitoring
- Backup
- Disaster Recovery

3. Risk Assessment Objectives

The objectives of this methodology are to:

- Protect the confidentiality of information assets.
- Protect the integrity of banking information and business processes.
- Maintain the availability of critical banking services.
- Support compliance with applicable legal, regulatory, and contractual requirements.
- Enable consistent and objective risk evaluation.
- Support management in making informed, risk-based decisions.
- Prioritize information security risks according to business impact.
- Support continual improvement of the Information Security Management System (ISMS).

4. Risk Assessment Process

Information security risks shall be assessed using the following process.

4.1 Identify Assets

Identify the information assets within the approved ISMS scope.

Examples include: Information, Applications, Databases, Servers, Network Devices, Cloud Services, Business Processes, Personnel, and Supporting Technologies.

4.2 Identify Threats

Identify potential threats that may negatively affect each asset.

Examples include: Phishing, Ransomware, Malware, Insider Threats, Unauthorized Access, Denial of Service, Hardware Failure, Human Error, and Natural Disasters.

4.3 Identify Vulnerabilities

Identify weaknesses that may allow threats to compromise an asset.

Examples include: Weak Passwords, Missing Security Patches, Poor Access Control, Misconfigured Systems, Lack of Encryption, Inadequate Monitoring, and Outdated Software.

4.4 Identify Existing Controls

Identify and document the security controls currently implemented to reduce the identified risks.

Examples include: Firewalls, Multi-Factor Authentication (MFA), Encryption, Security Monitoring, Backup, Endpoint Protection, Security Policies, Access Control, and Security Awareness Training.

4.5 Assess Likelihood

Determine the likelihood that a threat could successfully exploit a vulnerability.

Score 1 — Rare: Very unlikely to occur.
Score 2 — Unlikely: Could occur occasionally but is not expected.
Score 3 — Possible: May occur under normal operating conditions.
Score 4 — Likely: Expected to occur in many situations.
Score 5 — Almost Certain: Expected to occur frequently.

4.6 Assess Impact

Determine the potential business impact if the identified risk materializes.

Score 1 — Insignificant: Minimal impact with little or no business disruption.
Score 2 — Minor: Limited operational or financial impact.
Score 3 — Moderate: Noticeable disruption requiring management attention.
Score 4 — Major: Significant operational, financial, legal, or reputational impact.
Score 5 — Catastrophic: Severe impact affecting critical banking operations, regulatory compliance, customer trust, or business continuity.

4.7 Calculate Risk Score

The overall risk score shall be calculated using the following formula:

Risk Score = Likelihood × Impact

Example: Likelihood = 4, Impact = 5, Risk Score = 20.

4.8 Determine Risk Level

Risk scores shall be classified as follows:

Score 1–4: Low
Score 5–9: Medium
Score 10–16: High
Score 17–25: Critical

4.9 Determine Risk Treatment

Each identified risk shall be assigned one of the following treatment decisions: Avoid, Mitigate, Transfer, or Accept.

The selected treatment decision shall be documented together with the justification and responsible owner.

4.10 Record Risks

All assessed risks shall be documented within the Risk Register.

Each risk record shall include: Asset, Threat, Vulnerability, Existing Controls, Likelihood, Impact, Risk Score, Risk Level, Treatment Decision, Risk Owner, Target Completion Date, and Review Status.

5. Risk Criteria

5.1 Likelihood Criteria

Likelihood represents the probability that a threat will successfully exploit a vulnerability. The approved five-level scale shall be used for all risk assessments.

5.2 Impact Criteria

Impact represents the potential consequences if a risk materializes.

Impact shall consider: Financial Loss, Operational Disruption, Regulatory Consequences, Customer Trust, Reputational Damage, Confidentiality, Integrity, and Availability.

6. Risk Acceptance Criteria

Risk treatment decisions shall be based on the calculated risk level.

Low: Risk may be accepted and monitored.
Medium: Management review is required before acceptance.
High: A Risk Treatment Plan is required.

Critical: Immediate treatment is required. Risk acceptance requires formal approval from Senior Management.

7. Risk Treatment Options

The organization shall apply one of the following treatment options.

Avoid — Eliminate the activity or condition that creates the risk.

Mitigate — Implement additional controls to reduce the likelihood or impact of the risk.

Transfer — Transfer part of the risk to another party through contractual agreements or insurance.

Accept — Accept the residual risk when it falls within the organization's approved risk acceptance criteria.

8. Risk Review

Information security risks shall be reviewed:

- At least annually.
- Following significant technology changes.
- Following major business changes.
- Following security incidents.
- Following audit findings.
- Following regulatory changes.
- Following major changes to the ISMS scope.

9. Roles and Responsibilities

Senior Management

- Approve this methodology.
- Review significant information security risks.
- Approve risk acceptance decisions where required.

Information Security Function

- Coordinate risk assessments.
- Maintain the Risk Register.

- Monitor risk treatment progress.

Risk Owners

- Assess assigned risks.
- Implement agreed treatment actions.
- Report changes affecting risk levels.

Internal Audit

- Independently review the effectiveness of the risk assessment methodology.
- Verify compliance with the approved process.

10. Continual Improvement

This methodology shall be reviewed periodically to ensure its continued suitability and effectiveness.

The methodology may be updated following:

- Changes in business operations.
- Technology changes.
- Regulatory changes.
- Risk assessment results.
- Audit findings.
- Security incidents.
- Management Review decisions.

Any updates shall be documented and approved by Senior Management before implementation.